

[SECURITY] [DSA 1571-1] New openssl packages fix predictable random number generator

- To: debian-security-announce@lists.debian.org
- Subject: [SECURITY] [DSA 1571-1] New openssl packages fix predictable random number generator
- From: Florian Weimer <fw@deneb.enyo.de>
- Date: Tue, 13 May 2008 14:06:39 +0200
- Message-id: <87od7az9v4.fsf@mid.deneb.enyo.de>
- Reply-to: debian-security@lists.debian.org

-----BEGIN PGP SIGNED MESSAGE-----
Hash: SHA1

Debian Security Advisory DSA-1571-1 security@debian.org
<http://www.debian.org/security/> Florian Weimer
May 13, 2008 <http://www.debian.org/security/faq>

Package : openssl
Vulnerability : predictable random number generator
Problem type : remote
Debian-specific: yes
CVE Id(s) : CVE-2008-0166

Luciano Bello discovered that the random number generator in Debian's openssl package is predictable. This is caused by an incorrect Debian-specific change to the openssl package (CVE-2008-0166). As a result, cryptographic key material may be guessable.

This is a Debian-specific vulnerability which does not affect other operating systems which are not based on Debian. However, other systems can be indirectly affected if weak keys are imported into them.

It is strongly recommended that all cryptographic key material which has been generated by OpenSSL versions starting with 0.9.8c-1 on Debian systems is recreated from scratch. Furthermore, all DSA keys ever used on affected Debian systems for signing or authentication purposes should be considered compromised; the Digital Signature Algorithm relies on a secret random value used during signature generation.

The first vulnerable version, 0.9.8c-1, was uploaded to the unstable distribution on 2006-09-17, and has since propagated to the testing and current stable (etch) distributions. The old stable distribution (sarge) is not affected.

Affected keys include SSH keys, OpenVPN keys, DNSSEC keys, and key material for use in X.509 certificates and session keys used in SSL/TLS connections. Keys generated with GnuPG or GNUTLS are not affected, though.

A detector for known weak key material will be published at:

<<http://security.debian.org/project/extra/dowkd/dowkd.pl.gz>>
<<http://security.debian.org/project/extra/dowkd/dowkd.pl.gz.asc>>
(OpenPGP signature)

Instructions how to implement key rollover for various packages will be

published at:

[<http://www.debian.org/security/key-rollover/>](http://www.debian.org/security/key-rollover/)

This web site will be continuously updated to reflect new and updated instructions on key rollovers for packages using SSL certificates. Popular packages not affected will also be listed.

In addition to this critical change, two other vulnerabilities have been fixed in the openssl package which were originally scheduled for release with the next etch point release: OpenSSL's DTLS (Datagram TLS, basically "SSL over UDP") implementation did not actually implement the DTLS specification, but a potentially much weaker protocol, and contained a vulnerability permitting arbitrary code execution (CVE-2007-4995). A side channel attack in the integer multiplication routines is also addressed (CVE-2007-3108).

For the stable distribution (etch), these problems have been fixed in version 0.9.8c-4etch3.

For the unstable distribution (sid) and the testing distribution (lenny), these problems have been fixed in version 0.9.8g-9.

We recommend that you upgrade your openssl package and subsequently regenerate any cryptographic material, as outlined above.

Upgrade instructions

- - - - -

```
wget url
    will fetch the file for you
dpkg -i file.deb
    will install the referenced file.
```

If you are using the apt-get package manager, use the line for sources.list as given below:

```
apt-get update
    will update the internal database
apt-get upgrade
    will install corrected packages
```

You may use an automated update by adding the resources from the footer to the proper configuration.

Debian GNU/Linux 4.0 alias etch

- - - - -

Source archives:

```
http://security.debian.org/pool/updates/main/o/openssl/openssl\_0.9.8c-4etch3.dsc
Size/MD5 checksum: 1099 5e60a893c9c3258669845b0a56d9d9d6
http://security.debian.org/pool/updates/main/o/openssl/openssl\_0.9.8c.orig.tar.gz
Size/MD5 checksum: 3313857 78454bec556bcb4c45129428a766c886
http://security.debian.org/pool/updates/main/o/openssl/openssl\_0.9.8c-4etch3.diff.gz
Size/MD5 checksum: 55320 f0e457d6459255da86f388dcf695ee20
```

alpha architecture (DEC Alpha)

```
http://security.debian.org/pool/updates/main/o/openssl/openssl\_0.9.8c-4etch3\_alpha.deb
Size/MD5 checksum: 1025954 d82f535b49f8c56aa2135f2fa52e7059
http://security.debian.org/pool/updates/main/o/openssl/libssl0.9.8-dbg\_0.9.8c-4etch3\_alpha.deb
Size/MD5 checksum: 4558230 399adb0f2c7faa51065d4977a7f3b3c4
http://security.debian.org/pool/updates/main/o/openssl/libssl0.9.8\_0.9.8c-4etch3\_alpha.deb
Size/MD5 checksum: 2620892 0e5efdec0a912c5ae56bb7c5d5d896c6
http://security.debian.org/pool/updates/main/o/openssl/libssl-dev\_0.9.8c-4etch3\_alpha.deb
```

4etch3_alpha.deb

Size/MD5 checksum: 2561650 affe364ebcabc2aa33ae8b8c3f797b5e

http://security.debian.org/pool/updates/main/o/openssl/libcrypto0.9.8-udeb_0.9.8c-4etch3_alpha.udeb

Size/MD5 checksum: 677172 5228d266c1fc742181239019dbad4c42

amd64 architecture (AMD x86_64 (AMD64))

http://security.debian.org/pool/updates/main/o/openssl/libssl0.9.8-dbg_0.9.8c-4etch3_amd64.deb

Size/MD5 checksum: 1654902 d8ad8dc51449cf6db938d2675789ab25

http://security.debian.org/pool/updates/main/o/openssl/libssl0.9.8_0.9.8c-4etch3_amd64.deb

Size/MD5 checksum: 891102 2e97e35c44308a59857d2e640ddf141a

http://security.debian.org/pool/updates/main/o/openssl/openssl_0.9.8c-4etch3_amd64.deb

Size/MD5 checksum: 992248 82193ea11b0bc08c74a775039b855a05

http://security.debian.org/pool/updates/main/o/openssl/libssl-dev_0.9.8c-4etch3_amd64.deb

Size/MD5 checksum: 2178610 fb7c53e5f157c43753db31885ff68420

http://security.debian.org/pool/updates/main/o/openssl/libcrypto0.9.8-udeb_0.9.8c-4etch3_amd64.udeb

Size/MD5 checksum: 580250 7fb3d7fee129cc9a4fb21f5c471dfbab

arm architecture (ARM)

http://security.debian.org/pool/updates/main/o/openssl/libssl0.9.8-dbg_0.9.8c-4etch3_arm.deb

Size/MD5 checksum: 1537440 c5ab48e9bde49ba32648fb581b90ba18

http://security.debian.org/pool/updates/main/o/openssl/libcrypto0.9.8-udeb_0.9.8c-4etch3_arm.udeb

Size/MD5 checksum: 516576 84385b137c731de3b86824c17affa9f3

http://security.debian.org/pool/updates/main/o/openssl/libssl-dev_0.9.8c-4etch3_arm.deb

Size/MD5 checksum: 2049882 7ed60840eb3e6b26c6856dc5776b0c

http://security.debian.org/pool/updates/main/o/openssl/openssl_0.9.8c-4etch3_arm.deb

Size/MD5 checksum: 1011698 abfa887593089ac0f1cd4e31154897ee

http://security.debian.org/pool/updates/main/o/openssl/libssl0.9.8_0.9.8c-4etch3_arm.deb

Size/MD5 checksum: 805912 a605625ea107252e9aebbc77902a63ed

hppa architecture (HP PA RISC)

http://security.debian.org/pool/updates/main/o/openssl/libssl0.9.8-dbg_0.9.8c-4etch3_hppa.deb

Size/MD5 checksum: 1585900 2cbe55764db351dc6c3c2d622aa90caf

http://security.debian.org/pool/updates/main/o/openssl/libssl-dev_0.9.8c-4etch3_hppa.deb

Size/MD5 checksum: 2248328 664fb0992b786ce067a7d878056fc191

http://security.debian.org/pool/updates/main/o/openssl/openssl_0.9.8c-4etch3_hppa.deb

Size/MD5 checksum: 1030782 21f445c541d5e5b7c16de1db9ee9d681

http://security.debian.org/pool/updates/main/o/openssl/libssl0.9.8_0.9.8c-4etch3_hppa.deb

Size/MD5 checksum: 945144 c1092f3bb94d920d0beaa372c9cab04e

http://security.debian.org/pool/updates/main/o/openssl/libcrypto0.9.8-udeb_0.9.8c-4etch3_hppa.udeb

Size/MD5 checksum: 631132 76339119275786b5e80a7a1b4cd26b71

i386 architecture (Intel ia32)

http://security.debian.org/pool/updates/main/o/openssl/libssl-dev_0.9.8c-4etch3_i386.deb

Size/MD5 checksum: 2086512 eeef437fb87ad6687cd953d5951aa472

http://security.debian.org/pool/updates/main/o/openssl/libssl0.9.8-dbg_0.9.8c-4etch3_i386.deb

Size/MD5 checksum: 5584696 6d364557c9d392bb90706e049860be66

http://security.debian.org/pool/updates/main/o/openssl/openssl_0.9.8c-4etch3_i386.deb

Size/MD5 checksum: 1000832 ed5668305f1e4b4e4a22fbd24514c758

http://security.debian.org/pool/updates/main/o/openssl/libcrypto0.9.8-udeb_0.9.8c-4etch3_i386.udeb

Size/MD5 checksum: 554676 dbad0172c990359282884bac1d141034

http://security.debian.org/pool/updates/main/o/openssl/libssl0.9.8_0.9.8c-4etch3_i386.deb

Size/MD5 checksum: 2717086 361fde071d18ccf93338134357ab1a61

ia64 architecture (Intel ia64)

http://security.debian.org/pool/updates/main/o/openssl/libcrypto0.9.8-udeb_0.9.8c-4etch3_ia64.udeb

Size/MD5 checksum: 801748 05b29fc674311bd31fe945036a08abd5

http://security.debian.org/pool/updates/main/o/openssl/libssl0.9.8_0.9.8c-4etch3_ia64.deb

Size/MD5 checksum: 1192192 56be85aceb4e79e45f39c4546bfecf4f

http://security.debian.org/pool/updates/main/o/openssl/libssl-dev_0.9.8c-4etch3_ia64.deb

Size/MD5 checksum: 2593418 f9edaea0a86c1a1cea391f890d7ee70f

http://security.debian.org/pool/updates/main/o/openssl/libssl0.9.8-dbg_0.9.8c-4etch3_ia64.deb

Size/MD5 checksum: 1569418 4b2cb04d13efabddddd0f6d3cefd9b

http://security.debian.org/pool/updates/main/o/openssl/openssl_0.9.8c-4etch3_ia64.deb

Size/MD5 checksum: 1071156 e1f487c4310ad526c071f7483de4cd1a

mips architecture (MIPS (Big Endian))

http://security.debian.org/pool/updates/main/o/openssl/openssl_0.9.8c-4etch3_mips.deb

Size/MD5 checksum: 1003816 f895a8bc714e9c373ee80f736b5af00b

http://security.debian.org/pool/updates/main/o/openssl/libssl-dev_0.9.8c-4etch3_mips.deb

Size/MD5 checksum: 2262266 004484e816d4fe5ff03fe6d7df38d7b7

http://security.debian.org/pool/updates/main/o/openssl/libssl0.9.8-dbg_0.9.8c-4etch3_mips.deb

Size/MD5 checksum: 1692606 e8273f5d123f892a81a155f14ba19b50

http://security.debian.org/pool/updates/main/o/openssl/libssl0.9.8_0.9.8c-4etch3_mips.deb

Size/MD5 checksum: 875558 44074bce1cde4281c5abcf45817f429d

http://security.debian.org/pool/updates/main/o/openssl/libcrypto0.9.8-udeb_0.9.8c-4etch3_mips.udeb

Size/MD5 checksum: 580130 b6b810d1c39164747e3ebc9df4903974

mipsel architecture (MIPS (Little Endian))

http://security.debian.org/pool/updates/main/o/openssl/libcrypto0.9.8-udeb_0.9.8c-4etch3_mipsel.udeb

Size/MD5 checksum: 566168 97963ca9b6ada94445fb25b3126655e9

http://security.debian.org/pool/updates/main/o/openssl/openssl_0.9.8c-4etch3_mipsel.deb

Size/MD5 checksum: 992712 41c2bbe984553d693f21c3ec349ea465

http://security.debian.org/pool/updates/main/o/openssl/libssl-dev_0.9.8c-4etch3_mipsel.deb

Size/MD5 checksum: 2255558 3c63936cd511975291b4230bef1a2e3b

http://security.debian.org/pool/updates/main/o/openssl/libssl0.9.8_0.9.8c-4etch3_mipsel.deb

Size/MD5 checksum: 860506 d580fbed6efd734245ea7a7bed225bb

http://security.debian.org/pool/updates/main/o/openssl/libssl0.9.8-dbg_0.9.8c-4etch3_mipsel.deb

Size/MD5 checksum: 1649300 3315d1406f995f5b6d2a4f958976a794

powerpc architecture (PowerPC)

http://security.debian.org/pool/updates/main/o/openssl/openssl_0.9.8c-4etch3_powerpc.deb

Size/MD5 checksum: 1002022 b2749639425c3a8ac493e072cfff358

http://security.debian.org/pool/updates/main/o/openssl/libssl0.9.8_0.9.8c-4etch3_powerpc.deb

Size/MD5 checksum: 895460 e15fbbbbcfe17e82bacc07f6febd9707

http://security.debian.org/pool/updates/main/o/openssl/libcrypto0.9.8-udeb_0.9.8c-4etch3_powerpc.udeb

Size/MD5 checksum: 585320 61488ea7f54b55a21f7147fe5bc3b0f0

http://security.debian.org/pool/updates/main/o/openssl/libssl0.9.8-dbg_0.9.8c-4etch3_powerpc.deb

Size/MD5 checksum: 1728384 539ee1a3fe7d9b89034ebfe3c1091b6f

http://security.debian.org/pool/updates/main/o/openssl/libssl-dev_0.9.8c-4etch3_powerpc.deb

Size/MD5 checksum: 2210792 82e9e27c6083a95c76c5817f9604178f

s390 architecture (IBM S/390)

http://security.debian.org/pool/updates/main/o/openssl/libcrypto0.9.8-udeb_0.9.8c-4etch3_s390.udeb

Size/MD5 checksum: 643008 4861c78ea63b6c3c08c22a0c5326d981

http://security.debian.org/pool/updates/main/o/openssl/libssl0.9.8-dbg_0.9.8c-4etch3_s390.deb

Size/MD5 checksum: 1632976 01d289d460622382b59d07950305764f

http://security.debian.org/pool/updates/main/o/openssl/libssl0.9.8_0.9.8c-4etch3_s390.deb

Size/MD5 checksum: 951404 d92bb390489bed0abff58f7a1ceade6b

http://security.debian.org/pool/updates/main/o/openssl/openssl_0.9.8c-4etch3_s390.deb

Size/MD5 checksum: 1014308 487c24f2af25797a857814af7c9c0d0b

http://security.debian.org/pool/updates/main/o/openssl/libssl-dev_0.9.8c-4etch3_s390.deb

Size/MD5 checksum: 2193782 f1fe472c802e929a57bd8c8560bd3009

sparc architecture (Sun SPARC/UltraSPARC)

http://security.debian.org/pool/updates/main/o/openssl/libssl0.9.8-dbg_0.9.8c-4etch3_sparc.deb

Size/MD5 checksum: 4091340 970453ebfab8152c9c44ae210fbaa2a4

http://security.debian.org/pool/updates/main/o/openssl/libcrypto0.9.8-udeb_0.9.8c-4etch3_sparc.udeb

Size/MD5 checksum: 539054 7be1258f74165c4b037e202d2048f8ce

http://security.debian.org/pool/updates/main/o/openssl/openssl_0.9.8c-4etch3_sparc.deb

Size/MD5 checksum: 1010536 6444d6cc6fd838c82716462aacd1cf84

http://security.debian.org/pool/updates/main/o/openssl/libssl-dev_0.9.8c-4etch3_sparc.deb

Size/MD5 checksum: 2108000 ab0d0ccc72764a26b7767cace520b269

http://security.debian.org/pool/updates/main/o/openssl/libssl0.9.8_0.9.8c-4etch3_sparc.deb

Size/MD5 checksum: 2126386 61ddc204ee650cdd0f2b56e358134e2b

These files will probably be moved into the stable distribution on its next update.

For apt-get: deb <http://security.debian.org/> stable/updates main
For dpkg-ftp: <ftp://security.debian.org/debian-security> dists/stable/updates/main
Mailing list: debian-security-announce@lists.debian.org
Package info: `apt-cache show <pkg>' and <http://packages.debian.org/<pkg>>
-----BEGIN PGP SIGNATURE-----
Version: GnuPG v1.4.6 (GNU/Linux)

iQEVAwUBSCmDjL97/wQC1SS+AQLZGgf8Dp7Rj1HmC4n0QowM9cRnzw24upFQ1bpq
SbkU/NhkoLORcMnXsnVPL30bmtPxlTjpWuKIuRGzudXBonXaZtX1N4rl9HDpN+gt
AZJdxweSSmwQNYvOyPRKDVJ1w/YYiaJnSIDNks6NqSNYSEAb5L3bHBeHDTgLsWMW
jYcF5GJSt8yG3GvA0FyFIPwJihr2YF/RmhpurGQf3X06S94cDsdLtr/K0cdmdWze
39E+2h3L34HGiwVUGK9uY8Gv0DCPqhQZ4157CteFpQwQoKzFSxYApruCm4QcFxV+
BxuB/M9M5tPwRX1s1ffG+q3YHK0mDnB9d2JqSwQ5TD9kxTiwEEY8sQ==
=lX6B

-----END PGP SIGNATURE-----

Reply to:

- debian-security-announce@lists.debian.org
- [Florian Weimer \(on-list\)](#)
- [Florian Weimer \(off-list\)](#)

-
- Prev by Date: [\[SECURITY\].\[DSA 1575-1\] New Linux 2.6.18 packages fix denial of service](#)
 - Next by Date: [\[SECURITY\].\[DSA 1576-1\] New openssl packages fix predictable randomness](#)
 - Previous by thread: [\[SECURITY\].\[DSA 1575-1\] New Linux 2.6.18 packages fix denial of service](#)
 - Next by thread: [\[SECURITY\].\[DSA 1576-1\] New openssl packages fix predictable randomness](#)
 - Index(es):
 - [Date](#)

- [Thread](#)